

Security Policy Manual for GRØUNDZERØ
MYESHA SHIPMAN
St. Petersburg College
Approved December 1st, 2024

SECURITY POLICY MANUAL TABLE OF CONTENTS

SECURITY POLICY MANUAL TABLE OF CONTENTS 2

GRØUNDZERØ – Acceptable Use Policy 3

GRØUNDZERØ – Data Classification Policy 6

GRØUNDZERØ – Privacy Policy 9

GRØUNDZERØ – Physical Security Policy 12

GRØUNDZERØ – Asset Management Policy 16

GRØUNDZERØ – Social Media Policy 20

GRØUNDZERØ – Access Control Policy..... 23

GRØUNDZERØ –Business Continuity Policy 26

GRØUNDZERØ – Acceptable Use Policy

Version Control

- Version: 1.0
- Effective Date: 10.18.2024
- Last Reviewed: 10.24.2024
- Next Review Date: 10.24.2025
- Approved by: MYESHA SHIPMAN, CIO

1.Introduction

GRØUNDZERØ focuses on ensuring the availability, confidentiality, and integrity of its systems and data. All staff must act in a responsible, ethical, and legal manner. All GRØUNDZERØ staff, consultants, and temporary staff are required to manage knowledge with care and discretion, whether written, electronic, or verbal.

Therefore, the handling of data must be per GRØUNDZERØ's information security policy and follow the listed guidelines and principles. To ensure this, the staff of GRØUNDZERØ are continuously trained and made aware of topics within cybersecurity and the GDPR with continuous training.

1.2 Policy Statement

All users of GRØUNDZERØ systems are responsible for ensuring the proper use of company resources in a manner that supports business objectives and upholds security standards. Any activity that compromises security, violates company rules, or endangers the organization's assets will be subject to disciplinary actions as outlined in this policy.

1.3 Scope

This policy applies to all employees, contractors, vendors, and third-party partners who access or use GRØUNDZERØ's network, systems, applications, and devices.

2. Acceptable Use Guidelines

2.1. General Usage

Users are granted access to systems, networks, and devices to fulfill job-related tasks.

All activities conducted using company systems must be professional and align with company goals.

Users must comply with all applicable legal requirements, including data protection laws (GDPR, HIPAA, etc.).

2.2. Account and Access Control

Accounts are strictly personal and must not be shared with others.

Users must protect their login credentials and immediately report any suspected compromise.

Access to systems and data is based on the principle of least privilege, and users may only access data required to perform their job functions.

2.3. Network and Device Security

All devices accessing company resources must have up-to-date security patches and antivirus software installed.

Personal devices are prohibited from accessing company resources unless authorized and protected under the company's BYOD (Bring Your Own Device) policy.

2.4 Data Protection and Confidentiality

Confidential company data must be encrypted when stored or transmitted.

Sharing sensitive or proprietary data with unauthorized individuals is prohibited.

Users must adhere to the organization's data classification and handling policies.

2.5 Internet and Email Usage

The company's internet access is intended for business purposes. Personal use must be limited and not interfere with job responsibilities.

Users are prohibited from accessing, downloading, or distributing illegal, inappropriate, or malicious content.

All emails containing sensitive data must be encrypted or secured according to company guidelines.

3. Policy Exceptions

Exceptions to this policy may be granted in limited circumstances where a valid business need exists. Requests for exceptions must be submitted in writing to the GRØUNDZERØ's Information Security Department for review and approval.

4. Monitoring and Privacy

The organization reserves the right to monitor all network activity, including internet usage, emails, and file transfers, to ensure compliance with this policy. Users should have no expectation of privacy when using company resources.

5. Incident Reporting

All security incidents, including potential data breaches, suspicious activity, or policy violations, must be reported immediately to the Information Security Department.

6. Policy Enforcement

Violations of this policy may result in disciplinary actions up to and including termination of employment, legal action, or revocation of access rights. The Information Security Department is responsible for enforcing this policy and investigating violations.

7. Acknowledgment

All users are required to sign the acknowledgment form below, indicating that they have read, understood, and agree to comply with this Acceptable Use Policy.

Acknowledgment of Acceptable Use Policy

I acknowledge that I have read and understand the GRØUNDZERØ's Acceptable Use Policy, and I agree to abide by its terms and conditions.

Name: _____

Signature: _____

Date: _____

GRØUNDZERØ – Data Classification Policy

Version Control

- **Version: 1.0**
- **Effective Date: 10.18.2024**
- **Last Reviewed: 10.26.24**
- **Next Review Date: 10.26.25**
- **Approved by: MYESHA SHIPMAN, CIO**

1. Introduction

GRØUNDZERØ's information and data assets will be classified according to this policy to prevent unauthorized access, protect business interests, and maintain data integrity. Employees, contractors, and third-party affiliates are responsible for ensuring data is handled according to its assigned classification level.

2. Scope

This policy applies to all employees, contractors, and partners who handle, process, or store data within GRØUNDZERØ's environment. It covers all forms of data, including electronic, physical, cloud-based, and archived information.

3. Data Classification Levels

All data within GRØUNDZERØ will be classified into the following levels, each reflecting sensitivity, access requirements, and handling expectations:

3.1. Confidential

Definition: Data critical to GRØUNDZERØ's operations, the exposure of which could lead to significant legal, financial, or reputational damage.

Examples: Trade secrets, proprietary software code, executive communications, and customer financial information.

Handling Requirements:

- Access is restricted to authorized personnel only.
- Encryption is required for data at rest and in transit.
- Data must not be stored on personal devices without CIO approval.

3.2. Internal Use Only

Definition: Information intended for internal use but not harmful if accessed by employees.

Examples: Internal project documentation, non-public company strategies, and internal communications.

Handling Requirements:

- Access is limited to employees or contractors with a business need.
- Storage in approved locations only (e.g., secure internal drives).
- Sharing with third parties requires approval from the CIO.

3.3. Public

Definition: Information approved for public access without risks to GRØUNDZERØ.

Examples: Published marketing materials, publicly released announcements, and company contact information.

Handling Requirements:

- No restrictions on access; intended for broad distribution.
- Data must still be protected against unauthorized modifications.

4. Responsibilities

Each employee is responsible for appropriately handling data in accordance with its classification level. Managers and team leads are accountable for ensuring team compliance, and any discrepancies must be reported to the Information Security Team immediately.

5. Policy Exceptions

Exceptions to this policy may be granted only by MYESHA SHIPMAN (CEO and CIO) upon submission of a formal request that includes a business justification. All exceptions must be documented and periodically reviewed for continued relevance.

6. Monitoring and Policy Enforcement

GRØUNDZERØ reserves the right to monitor and audit data handling practices to ensure compliance with this policy. Violations of the Data Classification Policy may lead to disciplinary actions, including termination and/or legal action as necessary.

7. Acknowledgment

All employees must sign the acknowledgment form below, confirming that they have read, understood, and agreed to comply with this Data Classification Policy.

Name: _____

Signature: _____

Date: _____

GRØUNDZERØ – Privacy Policy

Version Control

- **Version:** 1.0
- **Effective Date:** 10.18.24
- **Last Reviewed:** 10.27.24
- **Next Review Date:** 10.27.25
- **Approved by:** MYESHA SHIPMAN, CIO

Introduction

At GRØUNDZERØ, we understand the sensitivity of personal information and are committed to its secure handling and protection. Our policies and procedures are designed to comply with the Personal Information Protection and Electronic Documents Act (PIPEDA) and other applicable privacy laws. We take appropriate measures to ensure that personal information is collected, used, and disclosed in accordance with these standards and the requirements set forth in the NIST Privacy Framework (Version 1.0).

Scope

This policy applies to:

- All employees, contractors, and third-party vendors.
- All data, including client information, employee records, and business operations data.
- All systems, applications, and processes that handle sensitive or personal data.

Policy Objectives

1. Protect the privacy of all data in compliance with military standards and applicable laws such as GDPR, CCPA, and HIPAA (if relevant).
2. Prevent unauthorized access, use, or disclosure of data.
3. Ensure that data is collected, processed, and stored responsibly and securely.
4. Establish a clear framework for responding to privacy breaches.

Key Components

1. Data Collection and Use

- GRØUNDZERØ only collects data necessary for business operations.
- Data will be collected transparently, and individuals will be informed about the purpose of data collection.
- Collected data includes:
 - Employee and contractor details (e.g., name, contact information, social security numbers).
 - Client data necessary for project delivery and security. (FIPA, 2014).

2. Data Storage and Protection

- All sensitive data will be stored securely in encrypted formats using **AES-256 encryption**, as recommended by military and NIST standards.
- Access to data is role-based and restricted to authorized personnel only.

3. Data Sharing and Disclosure

- GRØUNDZERØ does not share personal data with third parties unless required for business operations or mandated by law.
- Third-party vendors handling data must sign a **Data Protection Agreement (DPA)** and comply with the same privacy and security standards as GRØUNDZERØ.

4. Employee Responsibilities

- Employees must handle all data according to this policy.
- Use secure methods (e.g., encrypted emails) to transmit sensitive information.
- Report any suspected data breaches immediately to the Privacy Officer.

5. Privacy by Design

- All new systems or processes will incorporate **Privacy by Design** principles to minimize the collection and use of personal data.

6. Data Retention and Disposal

- Data will be retained only for as long as necessary to meet legal, contractual, and operational obligations.
- When no longer needed, data will be securely deleted or destroyed using **DoD-compliant data sanitization methods**.

7. Incident Response and Breach Notification

- In the event of a privacy breach:
 - Affected parties will be notified within 72 hours of discovery, in compliance with GDPR and similar frameworks.
 - A root cause analysis will be conducted, and corrective measures implemented to prevent recurrence.

Policy Enforcement

- Non-compliance with this policy may result in disciplinary action, up to and including termination.
- Violations involving sensitive data will be escalated to the CEO, CIO, and legal authorities, if necessary.

Exceptions

Exceptions to this policy must be approved in writing by the CEO or CIO and documented with a rationale and expiration date.

Implementation

1. **Training:** All employees will receive annual privacy and security training to ensure compliance.
2. **Audits:** Regular audits will assess compliance with this policy and related standards.
3. **Monitoring:** Systems will be monitored continuously to detect unauthorized data access or misuse.

GRØUNDZERØ – Physical Security Policy

Version Control

- **Version:** 1.0
- **Effective Date:** 10.18.24
- **Last Reviewed:** 11.19.24
- **Next Review Date:** 11.19.25
- **Approved by:** MYESHA SHIPMAN, CIO

Introduction

The Physical Security Policy protects the physical assets and equipment of GRØUNDZERØ's information technology (IT) and manages physical risks to the organization's assets and facilities. This policy is consistent with the requirements of a military contractor, and it complies with the following standards and frameworks: NIST SP 800-53 and ISO/IEC 27001.

Purpose

The purpose of this policy is to:

1. Safeguard IT assets from physical risks.
2. Define security measures to prevent unauthorized physical access.
3. Ensure the safety and availability of sensitive equipment and data.

Scope

This policy applies to all GRØUNDZERØ facilities, employees, contractors, and visitors with access to physical IT assets such as servers, desktops, laptops, and networking equipment.

Policy Guidelines

1. Facility Access Controls

- Only authorized personnel are allowed access to secured areas containing IT assets (e.g., server rooms).
- Access will be granted via keycards, biometrics, or PIN codes, as determined by the CIO.
- Visitors must sign in, wear badges, and be escorted at all times.

2. Equipment Protection

- All IT assets must be locked in secure locations when not in use.
- Portable devices (e.g., laptops) must be stored in locked cabinets or drawers when not in use.
- Critical IT equipment, such as servers, must be located in areas with restricted access and monitored by security cameras. (ISO/IEC 27001:2013)

3. Environmental Controls

- Server rooms and other critical infrastructure areas must be equipped with:
 - Fire suppression systems.
 - Temperature and humidity controls.
 - Backup power supply (e.g., UPS or generators).

4. Monitoring and Surveillance

- Security cameras will monitor entry and exit points, server rooms, and other critical areas.
- Security footage will be retained for a minimum of 90 days.

5. Employee Responsibilities

- Employees must wear ID badges at all times in the office.
- Report any unauthorized physical access or suspicious activity immediately to the CIO.

Policy Enforcement

Violations of this policy may result in disciplinary action, including termination and legal consequences.

Physical Security Policy Checklist

Purpose: This checklist ensures compliance with GRØUNDZERØ's Physical Security Policy and aligns with NIST SP 800-53 and ISO/IEC 27001 frameworks. It aids in identifying gaps and sustaining strong security processes.

1. Facility Access Controls

- ☐ Are keycards, PIN codes, or biometric systems used to secure restricted areas? *(NIST SP 800-53 Rev. 5, 2020; ISO/IEC 27001:2013)*
- ☐ Are visitor logs maintained and regularly reviewed? *(ISO/IEC 27001:2013)*
- ☐ Are visitors required to wear badges and remain escorted in secure areas? *(NIST SP 800-53 Rev. 5, 2020)*

2. Equipment Protection

- ☐ Are all portable devices (e.g., laptops, tablets) securely stored in locked cabinets or drawers when not in use? *(ISO/IEC 27001:2013)*
- ☐ Is critical IT infrastructure (e.g., servers) located in restricted areas with physical access controls? *(NIST SP 800-53 Rev. 5, 2020)*

3. Environmental Controls

- ☐ Are fire suppression systems (e.g., sprinklers, extinguishers) installed and operational in critical areas? *(ISO/IEC 27001:2013)*
- ☐ Are temperature and humidity controls active and monitored in server rooms? *(NIST SP 800-53 Rev. 5, 2020)*

4. Monitoring and Surveillance

- ☐ Are security cameras installed and actively monitoring entry points and critical areas? *(ISO/IEC 27001:2013)*
- ☐ Are surveillance recordings retained for at least 90 days? *(NIST SP 800-53 Rev. 5, 2020)*

5. Employee Responsibilities

- ☐ Are employees required to wear ID badges at all times in the office? *(NIST SP 800-53 Rev. 5, 2020)*
- ☐ Is there a clear protocol for reporting unauthorized access or suspicious activity? *(ISO/IEC 27001:2013)*

6. Incident Response

- ☐ Are physical security incidents documented and reviewed to prevent recurrence?
(NIST SP 800-53 Rev. 5, 2020)
- ☐ Are corrective actions taken after incidents in alignment with policy guidelines?
(ISO/IEC 27001:2013)

GRØUNDZERØ – Asset Management Policy

Version Control

- **Version:** 1.0
- **Effective Date:** 10.27.24
- **Last Reviewed:** 10.27.24
- **Next Review Date:** 10.20.25
- **Approved by:** MYESHA SHIPMAN, CIO

This policy aims to:

- Define the processes for identifying, labeling, and tracking assets.
- Protect GRØUNDZERØ's assets against unauthorized access, theft, or loss.
- Ensure effective use of resources by accurately tracking asset life cycles.
- Outline disposal procedures that safeguard data and maintain compliance with military regulations.

Policy Statement

All physical and digital assets owned or managed by GRØUNDZERØ must be tracked, maintained, and protected according to this policy. Employees are responsible for the care and management of any assets assigned to them, and the IT team is accountable for asset tracking and documentation.

1. Scope

This policy applies to all physical, digital, and intellectual property assets owned or leased by GRØUNDZERØ, including but not limited to:

- Hardware (computers, laptops, mobile devices, servers)
- Software (licensed software, proprietary applications)
- Network devices (routers, firewalls, switches)
- Intellectual property (designs, codes, documents)
- Office equipment and supplies

2. Asset Classification

All assets will be classified based on their value, sensitivity, and importance to GRØUNDZERØ's operations, in compliance with military asset management standards:

2.1. Critical Assets

- **Definition:** Assets vital to company operations and security; these assets require the highest level of protection and tracking.
- **Examples:** Core servers, primary databases, proprietary software.

2.2. Standard Assets

- **Definition:** Assets used in day-to-day operations with moderate sensitivity.
- **Examples:** Employee laptops, workstations, common-use software.

2.3. Peripheral Assets

- **Definition:** Non-critical assets used for auxiliary tasks.
- **Examples:** Monitors, peripherals (e.g., keyboards, mice), general office supplies.

3. Asset Management Lifecycle

GRØUNDZERØ manages assets through the following lifecycle stages:

3.1. Acquisition

- Assets will be acquired only after approval from the relevant department head or the CIO.
- Each new asset will be tagged and documented in the Asset Inventory Register, detailing its classification, assigned owner, and location.

3.2. Maintenance

- Employees must ensure the proper upkeep of assigned assets.
- Critical assets will be regularly monitored, patched, and updated by the IT team to ensure functionality and security.

3.3. Transfer

- Any asset transfer between employees, departments, or locations must be documented in the Asset Inventory Register.
- The receiving individual must acknowledge asset responsibility via the digital signature form.

3.4. Disposal

- All retired assets will be sanitized to remove sensitive data, following NIST, ISO 27001, and military disposal guidelines.
- Hardware disposal must be conducted through approved recycling and disposal services.
- A final disposal record will be maintained to document the date and method of disposal.

4. Roles and Responsibilities

4.1. IT Department

- Responsible for maintaining the Asset Inventory Register.
- Conducting regular asset audits and coordinating asset transfers or disposal.

4.2. Employees

- Required to care for assigned assets and report any damage, loss, or theft immediately.
- Must ensure assets are used solely for authorized purposes and in accordance with the Acceptable Use Policy.

4.3. Department Heads

- Approve asset acquisitions, transfers, or disposals as needed.
- Ensure department compliance with the Asset Management Policy.

5. Policy Exceptions

Exceptions to this policy must be approved by the CIO, with a documented business rationale. Each exception will be reviewed periodically to assess continued relevance and adherence.

6. Monitoring and Policy Enforcement

GRØUNDZERØ reserves the right to monitor asset usage, including physical audits and inventory reviews, to ensure compliance with this policy. Violations may result in disciplinary action, up to and including termination.

Acknowledgment

Employees must acknowledge their understanding of the Asset Management Policy and agree to comply with its terms.

Acknowledgment of Asset Management Policy

I acknowledge that I have read and understand the GRØUNDZERØ Asset Management Policy and agree to adhere to the asset care and management responsibilities outlined.

Name: _____

Signature: _____

Date: _____

GRØUNDZERØ – Social Media Policy

Version Control

- **Version:** 1.0
- **Effective Date:** 10.20.24
- **Last Reviewed:** 11.05.24
- **Next Review Date:** 11.05.25
- **Approved by:** MYESHA SHIPMAN, CIO

Policy Statement

Employees are expected to adhere to this policy's guidelines regarding social media usage to protect the interests, security, and reputation of GRØUNDZERØ. Any violations of this policy may result in disciplinary actions, as determined by the CIO, CFO, or designated authority.

1. Scope

This policy applies to all GRØUNDZERØ employees, contractors, and consultants. It covers behavior on social media platforms, personal and professional, and includes content shared about GRØUNDZERØ.

2. Social Media Behavior

2.1. Acceptable Behavior

- **Professional Use Only During Work Hours:** Social media usage during work hours is limited to employees with job-related responsibilities that require social media access, such as marketing or public relations roles. For others, social media use is prohibited during working hours to maintain productivity and security.
- **Privacy and Respect:** Employees should maintain professional conduct when referencing GRØUNDZERØ online, being respectful and accurate in any statements made. Respect for colleagues and the company's values is expected in all online interactions.

2.2. Unacceptable Behavior

- **Personal Use During Work Hours:** Employees are prohibited from using social media for personal purposes during work hours, except in designated break times and locations.
- **Prohibited Platforms:** Unless approved by the CIO or CFO, employees are restricted from using platforms that are not specified for business purposes. Social media channels are limited to pre-approved platforms aligned with GRØUNDZERØ's business and security objectives.
- **Negative Representation:** Employees must refrain from posting content that could damage GRØUNDZERØ's reputation, including disparaging remarks, confidential information, or unauthorized company images and documents.

3. Information Sharing Guidelines

3.1. Sharing Job Information

- **Position and Affiliation Disclosure:** Employees may disclose their job title and affiliation with GRØUNDZERØ at their discretion. However, they are reminded of their responsibility to ensure that their digital footprint aligns with the company's values and objectives.
- **Company-Related Content:** Posting company-related information, projects, or updates requires approval from management. Unauthorized sharing of such information could impact company security and privacy, and will be reviewed by the CIO, CFO, or relevant authority for appropriate action.

3.2. Confidentiality and Security Compliance

- **Prohibition of Confidential Information:** Employees must not share confidential or proprietary information related to GRØUNDZERØ, clients, or partners. Disclosure of trade secrets, business processes, financial data, or client information on social media is prohibited.
- **Personal Opinions vs. Company Representation:** Employees should make it clear that any personal opinions expressed are their own and do not represent GRØUNDZERØ. It is recommended to use disclaimers in profiles when discussing topics that could be associated with the company.

4. Off-Limits Platforms

- Any social media platform that is not specified by GRØUNDZERØ for business use or productivity is prohibited. Approval for using platforms outside of the designated list is granted on a case-by-case basis by the CIO or CFO.
- **List of Approved Platforms:** Platforms for professional networking and client engagement, such as LinkedIn or other approved channels, are allowed under company guidelines.

5. Employee Responsibilities and Consequences

- **Digital Responsibility:** Employees are responsible for their digital footprint and its impact on GRØUNDZERØ's reputation. Any violation of this policy that harms the company will be subject to review by the CIO, CFO, and potentially relevant authorities and stakeholders.
- **Consequences of Non-Compliance:** Non-compliance may result in disciplinary action, up to and including termination. Severe violations, such as sharing confidential information, may involve legal consequences.

6. Policy Exceptions

Exceptions to this policy must be approved by the CIO or CFO with a documented business rationale. Each exception will be reviewed periodically to assess continued relevance and adherence to GRØUNDZERØ's goals.

Monitoring and Enforcement

GRØUNDZERØ reserves the right to monitor employees' social media activity for compliance with this policy when applicable. Employees are encouraged to report any observed policy violations or issues that may have an impact on the company's security.

GRØUNDZERØ – Access Control Policy

Version Control

- **Version:** 1.0
- **Effective Date:** 10.18.24
- **Last Reviewed:** 11.22.24
- **Next Review Date:** 11.01.25
- **Approved by:** MYESHA SHIPMAN, CIO

Introduction

The purpose of the Access Control Policy is to protect the information systems and information stored within them from unauthorized access and to ensure that only authorized users are granted access to such systems and information. The policy also ensures that all users are assigned appropriate user roles and privileges based on the sensitivity of the information they will be handling.: (*NIST SP 800-53 Revision 5, 2020*). This is important to maintain the security posture of the organization and comply with the NIST SP 800-53 AC-2 standard on user access control. (NIST SP 800-53 Revision 5, 2020)

Purpose

The purpose of this policy is to:

1. Protect sensitive data and systems from unauthorized access.
2. Ensure access is granted based on business need and role.
3. Prevent and detect unauthorized system access.

Scope

This policy applies to all GRØUNDZERØ employees, contractors, and third-party vendors who access the company's systems, applications, and networks.

Policy Guidelines

1. Role-Based Access Control (RBAC)

- Access to systems and data will be granted based on job responsibilities and least privilege principles.
- The CIO will approve access levels for all users.

2. Authentication Requirements

- All systems must require strong passwords with the following criteria:
 - Minimum of 12 characters.
 - Must include uppercase letters, lowercase letters, numbers, and special characters.
- Multi-factor authentication (MFA) is mandatory for all sensitive systems.

3. User Account Management

- User accounts must be created, modified, or disabled by authorized personnel.
- Accounts of terminated employees must be deactivated within 24 hours.
- Shared accounts are prohibited unless approved by the CIO.

4. Monitoring and Logging

- All system access and user activity will be logged and reviewed regularly.
- Logs will be retained for a minimum of 6 months.

5. Remote Access

- Remote access is allowed only via company-approved VPNs.
- Devices used for remote access must comply with company security standards, including encryption and endpoint protection.

6. Data Access Restrictions

- Confidential and sensitive data, including military-related information, must be stored and accessed only from approved systems.
- Access to classified information requires additional clearance from the CIO. (DFARS, 2020).

Policy Enforcement

Violations of this policy will result in disciplinary action. This includes potential termination and will be escalated to the CEO and CIO.

GRØUNDZERØ –Business Continuity Policy

Version Control

- **Version:** 1.0
- **Effective Date:** 10.20.24
- **Last Reviewed:** 11.17.24
- **Next Review Date:** 11.17.25
- **Approved by:** MYESHA SHIPMAN, CIO

Policy Statement

GRØUNDZERØ is committed to maintaining and rapidly resuming key operations in the event of a crisis, such as a natural disaster, cyberattack, and/or other emergencies. This policy defines acceptable recovery times, prioritizes essential functions, and identifies key personnel needed during a crisis.

Policy Goals

1. Minimize disruption to operations and ensure rapid recovery.
2. Protect sensitive data and uphold client and stakeholder trust.
3. Define roles and responsibilities for continuity planning and crisis response.
4. Ensure compliance with military-grade standards and industry regulations.

Scope

This policy applies to:

- All GRØUNDZERØ employees, contractors, and vendors.
- All systems, processes, facilities, and assets that are essential to business continuity.
- Potential risks, including cyberattacks, system failures, natural disasters, and insider threats.

Key Policy Components

1. Acceptable Downtime and Recovery Time Objectives (RTO)

- **Mission-Critical Functions:** Must be restored within 24 hours. Examples: IT infrastructure, client communication systems, and cybersecurity operations.
- **Essential Functions:** Must be restored within 48 hours. Examples: financial systems, regulatory compliance activities.

- **Non-Critical Functions:** Can be restored within 72 hours or longer. Examples: HR and general administrative tasks.

2. Personnel and Roles During a Crisis

- **Crisis Management Team (CMT):**
 - Responsible for strategic decision-making and crisis oversight.
 - Members: CEO, IT Manager, Security Officer, and Operations Lead.
- **Essential Personnel:**
 - IT staff, security teams, and department leads must be available immediately during a crisis.
- **Non-Essential Personnel:**
 - May work remotely or delay activities based on priorities.

3. Critical Departments and Services

- **Always Available:** IT, cybersecurity, and client communication.
- **Priority Departments:** Financial services and supply chain management.
- **Secondary Departments:** HR, general administration, and marketing.

4. Risk Management

A proactive risk assessment will identify and prioritize potential threats, including:

- **Cybersecurity risks:** Data breaches, malware attacks, and system compromise.
- **Environmental risks:** Power outages, natural disasters, or infrastructure damage.

5. Testing and Maintenance

- Annual testing of the Business Continuity Policy to identify gaps and improve resilience.
- Regular updates to address changes in risks, technology, and business priorities.

Implementation

1. Compliance with Military-Grade Standards

- Align operations with NIST SP 800-34 for contingency planning. (Santos, 2019).
- Leverage best practices from the ISO 22301:2019 framework.
- Ensure secure communication protocols during crisis events.

2. Training and Awareness

All employees will receive mandatory training on their roles in business continuity, with a special focus on cybersecurity and operational priorities during crises.

3. Communication Plan

The CMT will oversee internal and external communications to provide updates on the status of operations during disruptions.

Enforcement

- Non-compliance with this policy will result in corrective action, up to and including termination.
- Major violations involving sensitive data or system security will be escalated to relevant authorities and stakeholders.

Policy Exceptions

All exceptions to this policy must be approved by the CEO and documented with a clear rationale statement.

GRØUNDZERØ Crisis Recovery Prioritization

Category	Function	RTO
Critical (Tier 1)	IT Infrastructure, Cybersecurity	24 hours
High Priority (Tier 2)	Finance, Regulatory Compliance	48 hours
Non-Critical (Tier 3)	HR, General Admin, Marketing	72 hours+

References

1. Calder, A. (2019). IT asset management: A best practice guide. IT Governance Publishing. ISBN: 978-1-78966-002-4.
2. Carnegie Mellon University, Software Engineering Institute. (n.d.). *CERT Insider Threat Resources*. Retrieved from <https://resources.sei.cmu.edu/library/>
3. Center for Internet Security. (2021). *CIS Controls Version 8*. Retrieved from <https://www.cisecurity.org/controls/v8/>
4. Data Classification Policy Guidance | Drata Help Center. (n.d.). Retrieved from <https://help.drata.com/en/articles/7172842-data-classification-policy-guidance>
5. Defense Federal Acquisition Regulation Supplement (DFARS). (2020). *Safeguarding covered defense information and cyber incident reporting*. Department of Defense.
6. Federal Emergency Management Agency (FEMA). (2020). *Continuity of operations (COOP) planning guidance*. Retrieved from <https://www.fema.gov>
7. Florida Information Protection Act (FIPA). (2014). *Florida Statutes Section 501.171*.
8. General Data Protection Regulation (GDPR). (2016). *Regulation (EU) 2016/679 of the European Parliament*.
9. Garrison, G., & Nolen, J. (2020). The role of asset management in cyber risk management: Bridging the gap between IT and OT. *Journal of Cybersecurity and Privacy*, 1(2), 188–206. <https://doi.org/10.3390/jcp1020012>
10. International Organization for Standardization. (2013). *ISO/IEC 27001:2013 - Information technology – Security techniques – Information security management systems – Requirements*.
11. International Organization for Standardization. (2019). *ISO 22301:2019 - Security and resilience – Business continuity management systems – Requirements*.
12. International Organization for Standardization. (2019). *ISO/IEC 27018:2019 - Information technology – Security techniques – Code of practice for protecting PII in cloud computing*.
13. International Organization for Standardization. (2022). *ISO/IEC 27002:2022 - Information security, cybersecurity and privacy protection — Information security controls*. Retrieved from <https://www.iso.org/standard/75652.html>
14. National Institute of Standards and Technology (NIST). (2010). *NIST Special Publication 800-34 Revision 1: Contingency planning guide for federal information systems*.
15. National Institute of Standards and Technology (NIST). (2020). *NIST Special Publication 800-53 Revision 5: Security and privacy controls for federal information systems and organizations*. U.S. Department of Commerce. Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

16. National Institute of Standards and Technology (NIST). (2020). *NIST Privacy Framework: A tool for improving privacy through enterprise risk management*.
17. Raghavan, S., & Lemaire, R. (2020). Information security asset management: A holistic approach. *International Journal of Information Management*, 50, 421–428.
<https://doi.org/10.1016/j.ijinfomgt.2019.05.002>
18. SANS Institute. (n.d.). *Information Security Policy Templates*. Retrieved from
<https://www.sans.org/information-security-policy/>
19. Santos, O. (2019). *Developing cybersecurity programs and policies* (3rd ed.). Pearson Education. ISBN-13: 978-0-7897-5940-5.
20. Thornild, A. B. (2024, January 24). *How to make an acceptable use policy – Example with free template*. CyberPilot. Retrieved from <https://www.cyberpilot.io/cyberpilot-blog/how-to-make-an-acceptable-use-policy>
21. California Consumer Privacy Act (CCPA). (2018). *State of California Civil Code 1798.100 et seq.*

Myesha M Shipman